



2016 中国互联网安全大会
China Internet Security Conference

协同联动 共建安全⁺命运共同体

employee

Industrial CyberSecurity Mission Centric Approach

Sergey Gordeyhchik | SCADA StrangeLove
Research Team

Group of security researchers focused on ICS/SCADA

Alexander Timorin
Alexander Tlyapov
Alexander Zaitsev
Alexey Osipov
Andrey Medov
Artem Chaykin
Denis Baranov
Dmitry Efanov
Dmitry Nagibin

Dmitry Serebryannikov
Dmitry Sklyarov
Evgeny Ermakov
Gleb Gritsai
Ilya Karpov
Ivan Poliyanchuk
Kirill Nesterov
Roman Ilin
Roman Polushin
Sergey Bobrov

Sergey Drozdov
Sergey Gordeychik
Sergey Sidorov
Sergey Scherbel
Timur Yunusov
Valentin Shilnenkov
Vladimir Kochetkov
Vyacheslav Egoshin
Yuri Goltsev
Yuriy Dyachenko

to **save** Humanity **from** industrial **disaster**
and to **keep Purity Of Essence**

CYBERSECURITY?

That cyber-word you keep using...



#RSAC

abuse	conflict	exercises	intelligence	ratings	storm	warriors
adversaries	cop	experts	issues	related	strategy	wars
alarm	crime	exposure	jihad	response	stress	weaponry
attack	criminals	firefight	kill	risk	talent	winter
battle	crisis	forensics	legislation	risks	technologies	<u>wisemen</u>
battlefield	crooks	fraud	mercenary	safety	terrorism	workforce
bomb	<u>csi</u>	front	notary	scenario	terrorist	world
breach	defense	fusion	officials	secrets	terrorists	
bullying	divide	gangs	operations	security	theft	
buzzword	dominance	<u>geddon</u>	panel	shock	threat	
cash	ecosystem	guardians	policies	situational	threats	
catastrophe	environment	identity	policy	skills	vigilante	
challenge	espionage	incident	predator	space	war	
coin	event	incidents	punk	spying	warfare	
cold	exercise	insurance	ranges	Stalking	warrior	

was for conference 2016

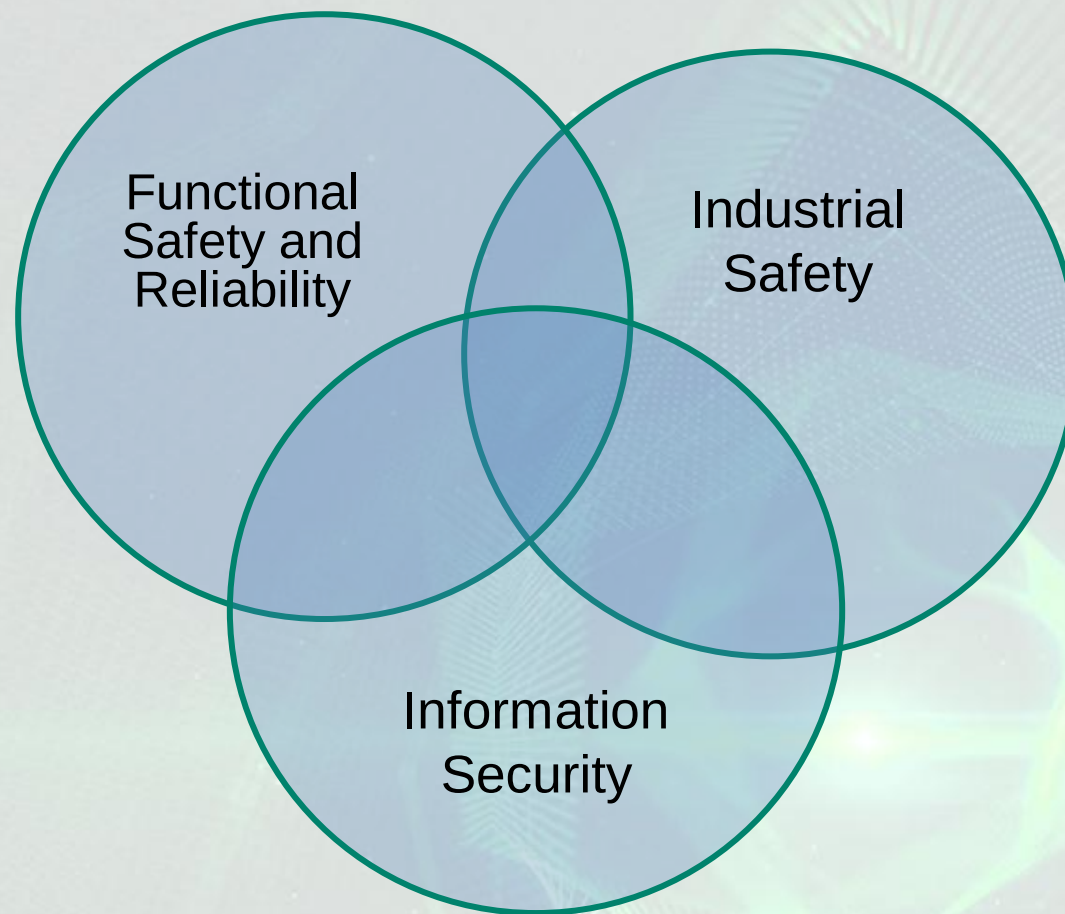


Cory Doctorow @doctorow · Apr 11

The perfect suffix for your "cyber-" buzzword

boingboing.net/2016/04/11/the...





THREATS?



中国互联网安全大会



360互联网安全中心

Squirrels are menacing the power grid: Rodents have disrupted electricity more than birds, racoons and China combined



CHRISTOPHER INGRAHAM, WASHINGTON POST | January 12, 2016 | Last Updated:

Jan 13 9:55 AM ET

[More from Washington Post](#)



Monkey causes nationwide blackout in Kenya

By [Tiffany Ap](#) and Lonzo Cook, CNN

Updated 0427 GMT (1227 HKT) June 8, 2016



Four Cyber Attacks On UK Railways In A Year

A security experts says the hackers could create "real disaster related to train safety".



Video: Sky News has learned that the UK railway network has suffered at least four major cyber attacks over the last year alone.

Ukrainian blackout caused by hackers that attacked media company, researchers say

Power company suffered a major attack that led to blackouts across western Ukraine, after an attack on a Ukrainian media company



Smokestacks in Dniprodzershynsk, Ukraine. Photograph: John Mcconnico/AP

<http://news.sky.com/story/four-cyber-attacks-on-uk-railways-in-a-year-10498558>

<https://www.theguardian.com/technology/2016/jan/07/ukrainian-blackout-hackers-attacked-media-company>

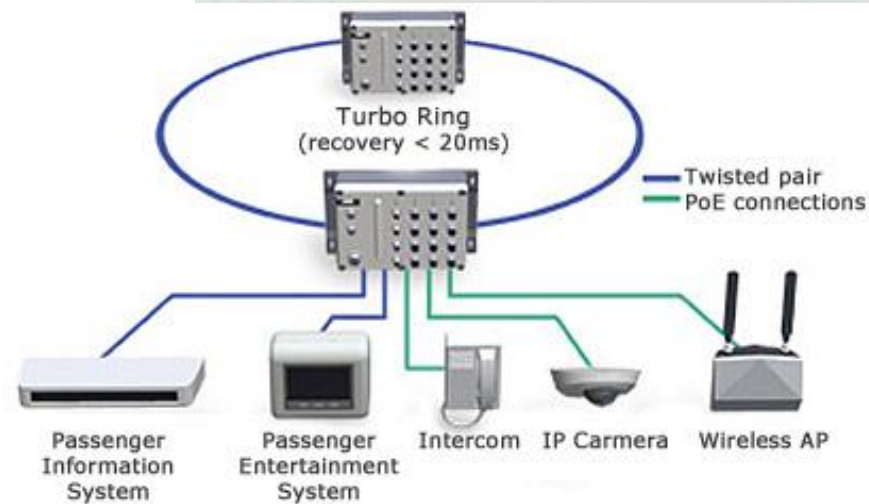
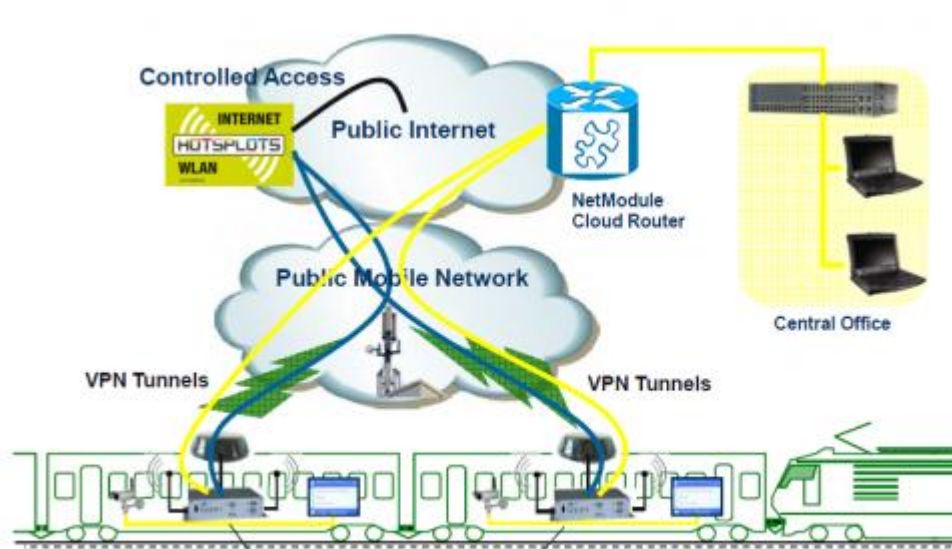
INTERCONNECTED WORLD



中国互联网安全大会



360互联网安全中心



fahrweg.dbnetze.com/fahrweg-en/technic/gsmr/sim_cards.html



DB Netz AG | Media | Network Access | Products&Services | **Infrastructure&Technology** | International

Enter search criteria

Infrastructure register

GSM-R

- Overview
- Train radio
- Shunting radio
- Public Roaming
- International Roaming
- Ordering of SIM cards**

ETCS

Infrastructure&Technology > GSM-R > Ordering of SIM cards

Ordering of SIM cards

GSM-R SIM cards

Information on SIM cards for national and foreign GSM-R customers.

SIM cards for national GSM-R customers

SIM cards can be ordered directly from the GSM-R Customer Service. Before placing the initial order for SIM cards, please transmit your

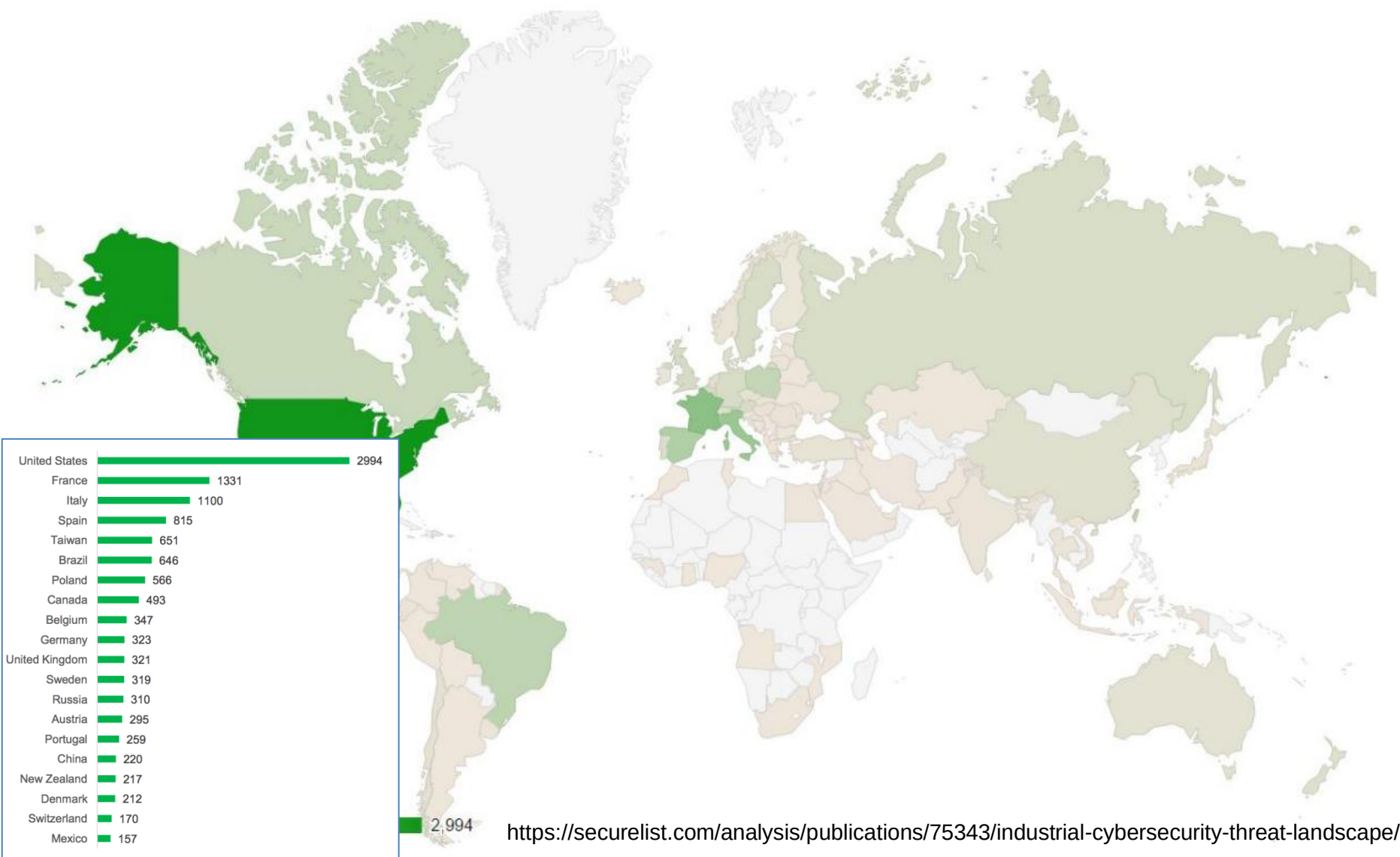
220,558 ONLINE, 17,042 IN ENTERPRISES



中国互联网安全大会



360互联网安全中心



ICS ONLINE: CHINA

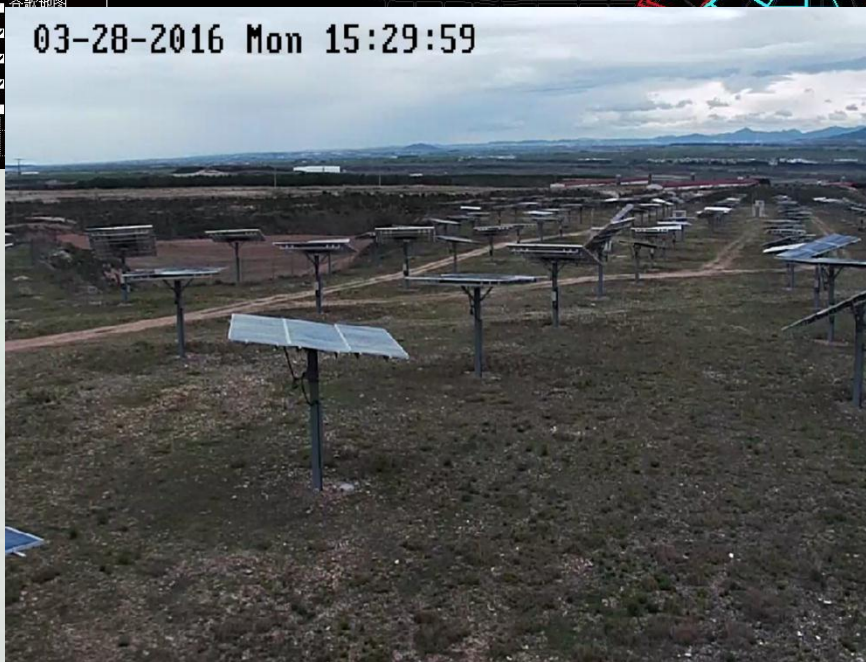


中国互联网安全大会



360互联网安全中心





~10,000 OF “SMART” POWER GRID OBJECTS

- GREEN ENERGY
- SMART GRID
- DIGITAL SUBSTATIONS

121,000 KM OF RAILWAYS

- 19,000 KM OF HIGH-SPEED LINES
- HIGHLY AUTOMATED
- NATIONAL HIGH-SPEED RAIL GRID (4+4)

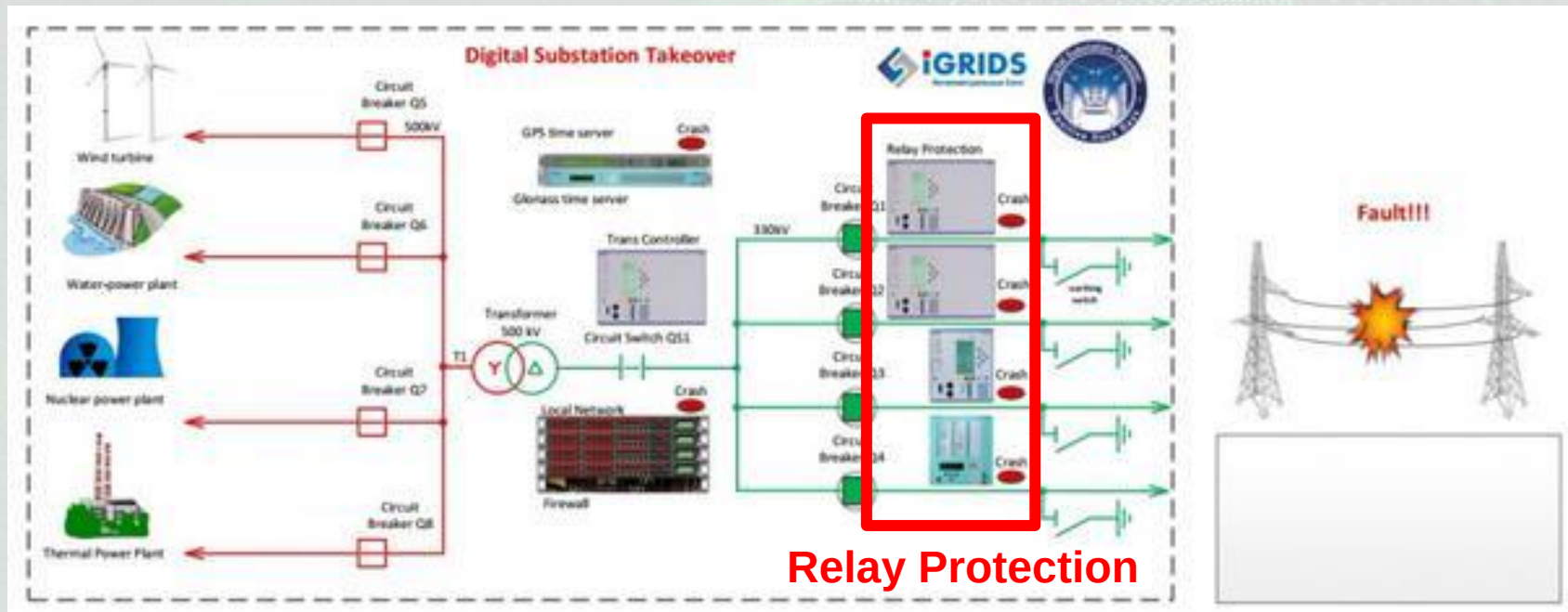
CTF-STYLE WHITE HAT INDUSTRIAL CHALLENGE



<http://www.phdays.com/press/news/41213/>

DIGITAL SUBSTATION TAKEOVER: GOALS

- FIND VULNERABILITIES IN IEC-61850 SUBSTATIONS
- CREATE EXPLOIT
- TRIGGER CYBER-PHISICAL ATTACK





VULNERABILITIES IN RELAY PROTECTION



中国互联网安全大会



360互联网安全中心

SSA-732541: Denial-of-Service Vulnerability in SIPROTEC 4

Publication Date 2015-07-17
Last Update 2015-07-17
Current Version V1.0
CVSS Overall Score 6.1

Summary

The latest firmware updates for SIPROTEC 4 and SIPROTEC Compact devices allow attackers to perform a denial-of-service attack.

AFFECTED PRODUCTS

- SIPROTEC 4 and SIPROTEC Compact Ethernet module EN100

Vulnerability 1 (CVE-2016-4784)

The integrated web server (port 80/tcp) of the affected devices could allow remote attackers to obtain sensitive device information if network access was obtained.

CVSS Base Score 5.0
CVSS Temporal Score 3.9
CVSS Overall Score 3.9 (AV:N/AC:L/Au:N/C:P/I:N/A:N/E:POC/RL:OF/RC:C)

Vulnerability 2 (CVE-2016-4785)

The integrated web server (port 80/tcp) of the affected devices could allow remote attackers to obtain a limited amount of device memory content if network access was obtained. This vulnerability only affects EN100 Ethernet module included in SIPROTEC 4 and SIPROTEC Compact devices.

CVSS Base Score 5.0
CVSS Temporal Score 3.9
CVSS Overall Score 3.9 (AV:N/AC:L/Au:N/C:P/I:N/A:N/E:POC/RL:OF/RC:C)

REMOTE CODE EXECUTION?



中国互联网络安全大会



360互联网安全中心

- to get firmware?
- to get debug symbols?
- to debug?
- ..PowerPC
- no “operation system”



CONFIRMATION CODE “311299”



中国互联网络安全大会



360互联网安全中心

To access this information, the confirmation code “311299” needs to be provided when prompted."

...Siemens does not publish official documentation on these statistics. It is strongly recommended to work together with Siemens SIPROTEC customer care or commissioning experts to retrieve and interpret **the statistics and test information...**"

```
- send packets:
15 bytes (0xf)
00000000 00 00 00 00 00 01 0d 06 00 01 00 00 a2 00 00 .....
00000000 00 00 00 00 00 02 0d 06 00 01 00 00 00 00 00 .....
00000010 00 a9 08 53 49 50 52 4f 54 45 43 30 34 2e 38 31 ... SIPROTEC04. 81
00000020 2e 30 34 32 39 2e 30 33 2e 31 31 00 23 df 18 45 .0429.03.11. #..E
00000030 d1 ca 64 20 37 53 4a 36 34 35 35 35 45 42 39 32 ..d 7SJ64555EB92
00000040 31 46 45 30 2d 2d 2d 2d 30 53 2d 2d 2d 2d 2d 2d 1FE0----0S-----
00000050 2d 2d 2d 2d 10 37 53 4a 36 34 23 23 2a 2a 40 23 ----.7SJ64###*@#
00000060 23 23 40 40 23 10 2d 2d 2d 2d 23 40 23 40 2d 2d ##@@#.----#@#@--
00000070 2d 2d 2d 2d 2d 2d 09 56 30 34 2e 38 31 2e 30 34 -----v04.81.04
00000080 09 56 30 34 2e 34 30 2e 30 31 08 30 32 2e 30 32 .v04.40.01.02.02
00000090 2e 30 31 0b 53 65 70 20 32 32 20 32 30 30 38 00 .01.Sep 22 2008.
000000a0 01 69 10 00 01 bd 84 00 00 71 1c 00 00 e3 fc 00 .i.....q.....
000000b0 02 e0 14 00 00 00 13 00 00 11 97 .....
finished
```


DEVICE MEMORY



中国网络安全大会



360互联网安全中心

- send packets:

15 bytes (0xf)

```
00000000 00 00 00 00 00 01 0d 06 00 01 00 00 a2 00 02
00000000 00 00 00 00 00 02 0d 06 00 01 00 00 00 37 fb 94
00000010 00 e2 2d 1c 78 00 00 28 0e 3c 00 01 0b 0c 38 00
00000020 02 17 0c 40 00 03 17 08 d8 00 04 1a 0a 44 00 05
00000030 0e 0c 78 00 06 16 0c 78 00 07 16 0c e8 00 08 13
00000040 0c d8 00 09 13 0f c0 00 0a 15 0e d4 00 0b 07 08
00000050 a0 00 0c 1c 0d fc 00 0d 0c 08 50 00 0e 1e 08 d0
00000060 00 0f 1a 0b 40 00 11 2b 0e 30 00 12 1d 25 34 00
00000070 17 06 ff ff 00 18 ff 0e 94 00 1a 08 08 68 00 1b
00000080 1d 07 a0 00 1d 24 0f 04 00 1e 06 1a 50 00 1f 11
00000090 08 d8 00 20 1a 0a 34 00 21 0e 20 a8 00 23 09 0c
000000a0 08 00 24 18 0c 18 00 25 18 0c 90 00 27 15 07 20
000000b0 00 28 37 0c e0 00 29 13 0a fc 00 2a 1f 0c d0 00
000000c0 2b 13 35 48 00 2c 10 ff ff ff ff ff ff ff ff
000000d0 ff ff ff ff ff ff ff ff ff ff ff ff ff ff ff
000000e0 ff ff ff ff ff ff ff ff ff ff ff ff ff ff ff
000000f0 ff ff ff ff
```

CONTROL DISP.

I

LAS1
LBS1
LCS1

645A
645A
629A

500kV

RESERV.

T1

hacked
by BAY

330kV

I

LAS2
LBS2
LCS2

0.98kA
0.98kA
0.98kA

f=
S=

50.00HZ
554MVA

<http://scadastrangelove.blogspot.com/2015/12/now-declared-capabilities.html>



中国互联网安全大会



360互联网安全中心

```
Terminal - user@nesterovk-nb:/home/user
File Edit View Terminal Tabs Help
user@nesterovk-nb ~ 16:10:09
$ nmap -T4 -F 192.168.0.42

Terminal - user@nesterovk-nb:/home/user
File Edit View Terminal Tabs Help
root@ubuntupt:~# nc -v -p 81 -l
```

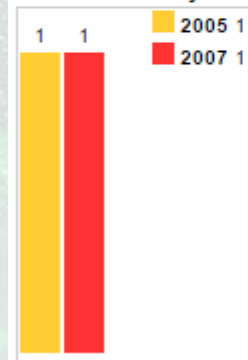

Linux VxWorks 6.x 61850 Stack Misfortune Cookie SSH server

Sisco : Vulnerability Statistics

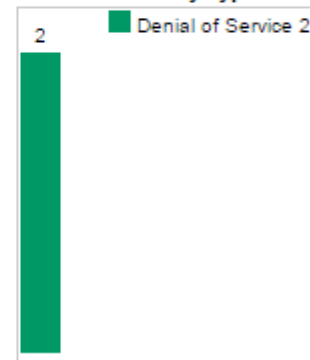
[Products \(6\)](#) [Vulnerabilities \(2\)](#) [Search for p](#)

[Vulnerability Feeds & Widgets](#)

Vulnerabilities By Year



Vulnerabilities By Type



Windriver » Vxworks : Security Vulnerabilities (CVSS score >= 5)

CVSS Scores Greater Than: 0 1 2 3 4 5 6 7 8 9

[Copy Results](#) [Download Results](#) [Select Table](#)

#	CVE ID	CWE ID	# of Exploits	Vulnerability Type(s)	Publish Date	Update Date	Score	Gained Access Level	Access
1	CVE-2015-3963	20			2015-08-03	2015-08-05	5.8	None	Remote
Wind River VxWorks before 5.5.1, 6.5.x through 6.7.x before 6.7.1.1, 6.8.x before 6.8.3, 6.9.x before 6.9.1 on Schneider Electric SAGE RTU devices before J2 and other devices, does not properly generate TCP initialization sequence numbers, which allows remote attackers to spoof TCP sessions by predicting an ISN value.									
2	CVE-2013-0716	20		DoS	2013-03-20	2013-05-20	5.0	None	Remote
The web server in Wind River VxWorks 5.5 through 6.9 allows remote attackers to cause a denial of service (CPU consumption) via a crafted HTTP request.									
3	CVE-2013-0714	20		DoS Exec Code	2013-03-20	2013-05-20	10.0	None	Remote
IPSSH (aka the SSH server) in Wind River VxWorks 6.5 through 6.9 allows remote attackers to execute arbitrary code via a crafted public-key authentication request.									

IPSSH (aka the SSH server) in Wind River VxWorks 6.5 through 6.9 allows remote attackers to execute arbitrary code via a crafted public-key authentication request.

Kudos @repdet @k_v_Nesterov @samincube

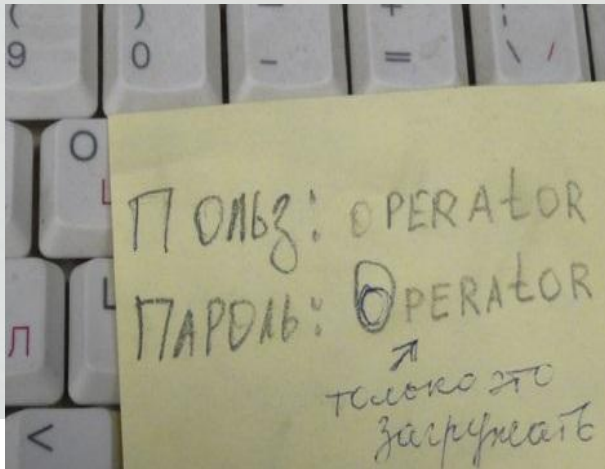
RAILWAY COMPUTER BASED INTERLOCKING



中国互联网络安全大会



360互联网安全中心



NEW EQUIPMENT & SYSTEM APPROVAL CERTIFICATE

Approval date: 17th February 2014

by: Safety & Environment Committee

no.: [REDACTED]

date: 30th January 2014



Trackguard

Flexible safety processor

List of acceptable software for Support Systems

Software	Version	Operating system required
	9.1.0	Windows XP (32 bit)
		Windows 7 (64 bit)
	9.0.0	Windows XP Service pack 2
		Windows NT4 service pack 6 and above
	8.1.1 Build 28	Windows 2000 Professional
		Windows XP Professional
	3.1.6.5	Windows 7



GSM-R CAB RADIO

Linux based operating, system, integrated GPS, WiFi support and the capacity for over the air (OTA) software updates. Fast in use and easy in configuration. Compatible call forwarding solution

Features

+ Do your modems support "over the air" / SMS SIM-card update?

The OTA (over the air) SIM card update is included in our modules.



5.1. Sending Commands by SMS

The first four characters of an SMS command must be the phone PIN code (the default is 1234). This is then followed by the command(s).

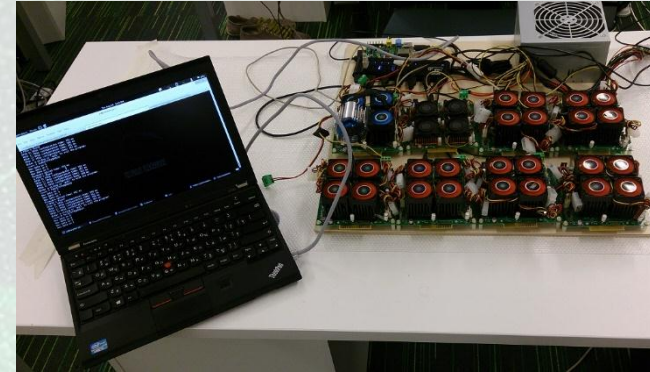
NOTE the PIN code referred to in this manual is a security code specifically for programming the telephone via SMS commands – it is not a lock code and is not related to the SIM card. It is not required for making or receiving calls.

Example 1: 1234STAT will return status information about the phone.

Example 2: 1234CFG5=1 configures the phone to inhibit incoming calls.

VULNERABILITIES OF (U)SIM

- Remote data recovery (Kc, TIMSI)
 - Chanel decryption (including A5/3)
 - «Clone» the SIM and mobile station
- SIM “malware”
- Block SIM via PIN/PUK brute
- Extended OTA features (FOTA)

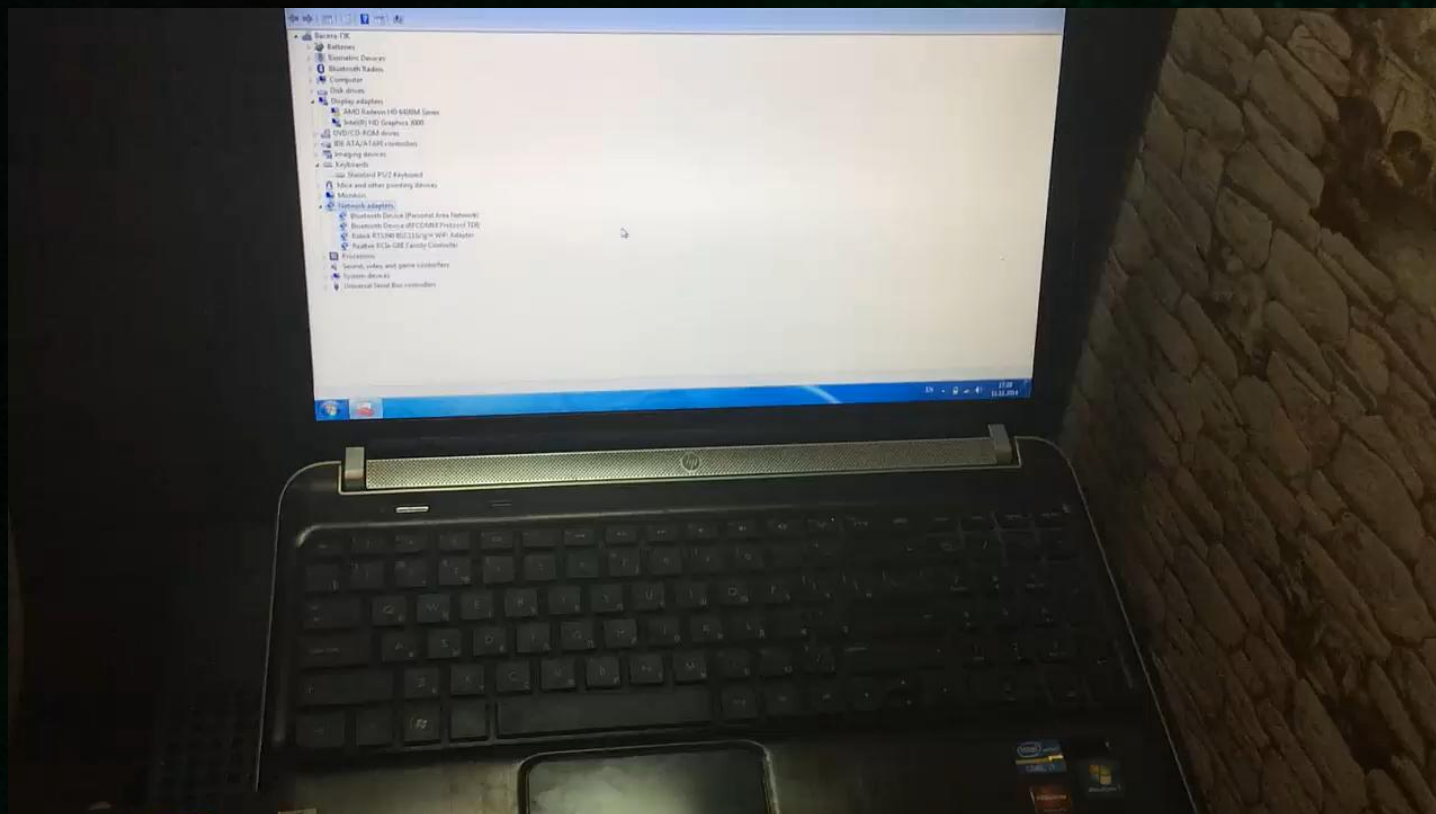


Hardware	Speed (Mcrypt/sec)	Time for DES (days)	Time for 3DES (part of key is known, days)
Intel CPU (Core i7-2600K)	475	1755,8 (~5 years)	5267,4
Radeon GPU (R290X)	3' 000	278	834
Single chip (xs6slx150-2)	7' 680	108,6	325,8
ZTEX 1.15y	30' 720	27,2	81,6
Our rig (8*ZTEX 1.15y)	245' 760	3,4	10,2

+ descrypt bruteforcer - <https://twitter.com/GiftsUngiven/status/492243408120213505>

Karsten Nohl, <https://srlabs.de/rooting-sim-cards/>

Alexander Zaitsev, Sergey Gordeychik, Alexey Osipov, PacSec, Tokyo, Japan, 2014



LOCAL VENDORS

(KL-NARI-2015-001) Kaspersky Lab Advisory

Access to local/remote files, writing arbitrary files to file system.

---[Affected Hardware]

NARI PCS-9611

(KL-NARI-2015-002) Kaspersky Lab Advisory

Stack overflow

---[Affected Hardware]

NARI PCS-9611

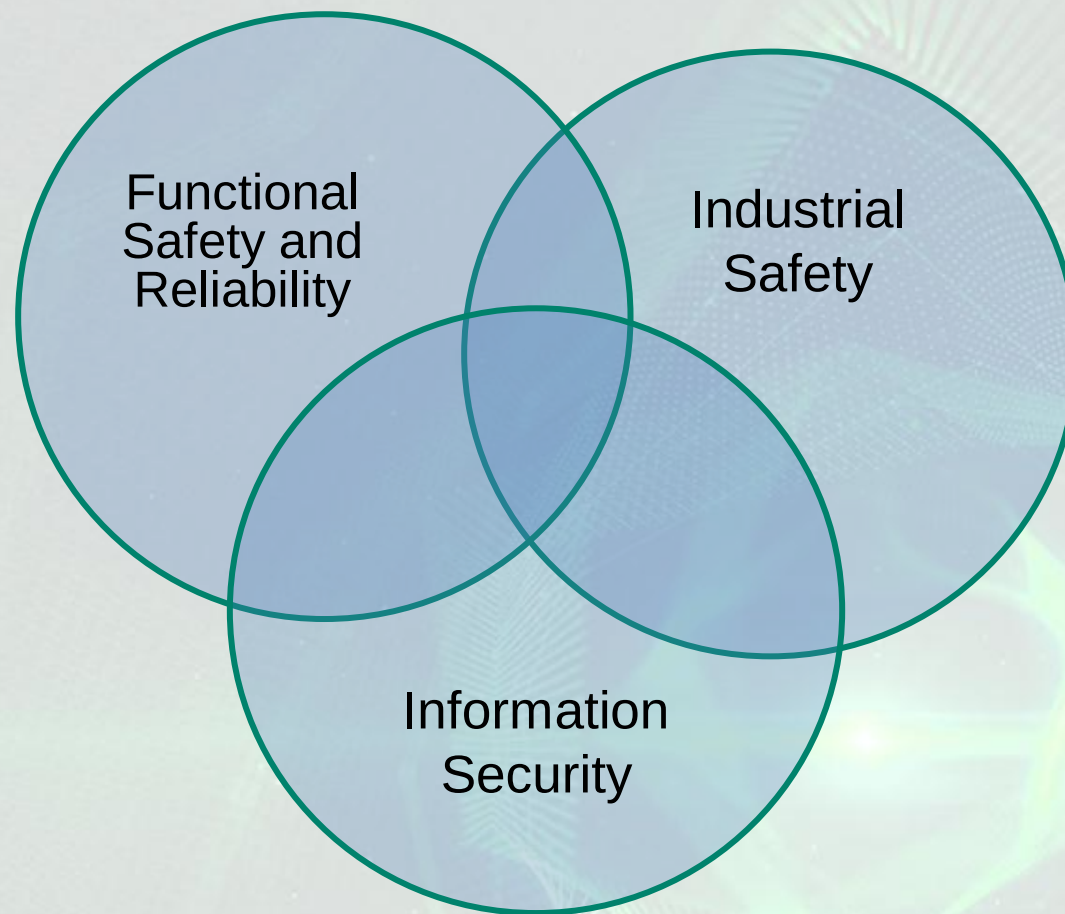
(KL-NARI-2015-003) Kaspersky Lab Advisory

Denial of service

---[Affected Hardware]

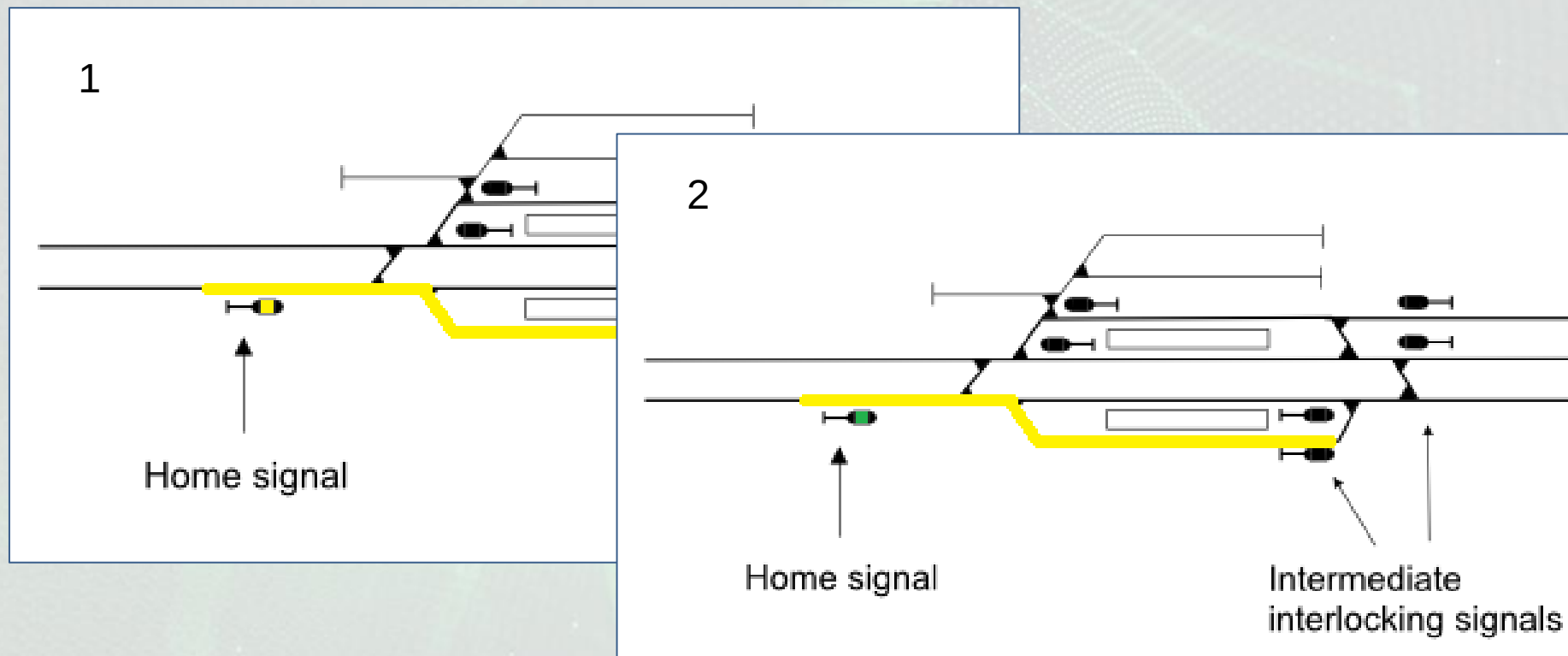
NARI PCS-9611





- ▶ **Industrial safety:** directly affect physical safety.
- ▶ **Economical:** decrease railroad traffic capacity or other quantitative economical characteristics (train delays, local power outage)
- ▶ **Reliability and functional safety impact:** ICS crashes, out of service, etc.

COMPUTER BASED INTERLOCKING



FORMAL REQUIREMENTS



中国互联网安全大会



360互联网安全中心

	PUBLIC TRANSPORT CORPORATION INFRASTRUCTURE DIVISION	ENG-SE-SPE-0000
		VERS Bundesministerium der Justiz und für Verbraucherschutz
SPECIFICATION		
COMPUTER BASED INTERLOCKING		

- 607.5 CBI Software
 - 607.5.1 Vital Logic Software
 - 607.5.2 Data Preparation Software
 - 607.5.3 Site Specific Data
- 607.6 Diversity
 - 607.6.1 Processor Safety
 - 607.6.2 Hardware Diversity
 - 607.6.3 Software Diversity
- 607.7 Maintenance Procedures
- 607.8 Security
 - 607.8.1 Degration o
 - 607.8.2 Site Specifi
 - 607.8.3 Version Cor
 - 607.8.4 Safety Relat
- 607.9 Functional Test
- 607.10 Vital Serial Links

- Startseite
- [Gesetze / Verordnungen](#)
- Aktualitätendienst
- Titelsuche
- Volltextsuche
- Translations

Eisenbahn-Bau- und Betriebsordnung

zur Gesamtausgabe der Norm im Format: [HTML](#) [PDF](#) [XML](#) [EPUB](#)

- [Inhaltsübersicht](#)
- [Eingangsformel](#)
- [Erster Abschnitt](#)
- [Allgemeines](#)
- [§ 1 Geltungsbereich](#)



"Об утверждении правил технической эксплуатации железных дорог Российской Федерации"

Дата официального опубликования: 08.04.2011

Дата вступления в силу: 01.09.2012

автобло

О КОМПАНИИ

ПРИ

ПАССАЖИРАМ ГРУ:

1. Safety (Cyber Physical Threats)

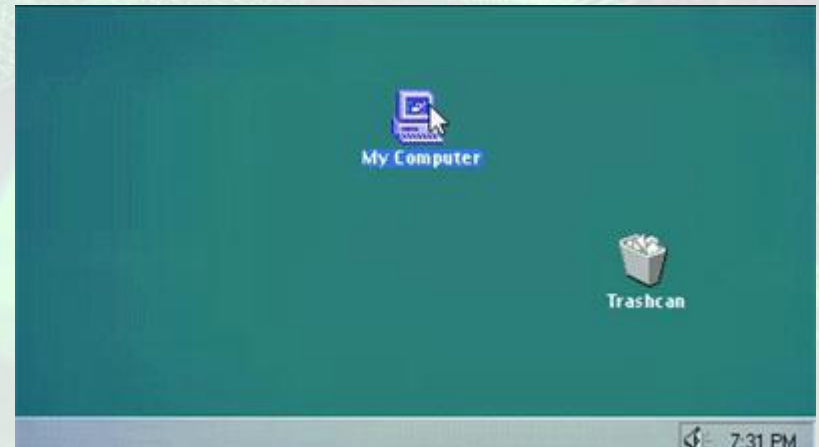
- set a less restrictive signal light
- operate a switch with a train passing over it
- set conflicting routes ...

2. Economics (freight efficiency)

- CBI CPU crash
- Blocking of control
- False indication...

3. Reliability and functional safety

- CBI CPU reboot
- Network crash...



Signalling cyber security: the need for a mission-centric approach
Valentin Gapanovich, Efim Rozenberg and Sergey Gordeychik

<http://www.railjournal.com/index.php/signalling/signalling-cyber-security-the-need-for-a-mission-centric-approach.html>

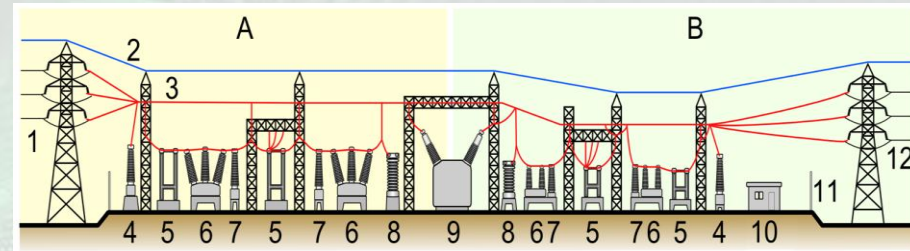
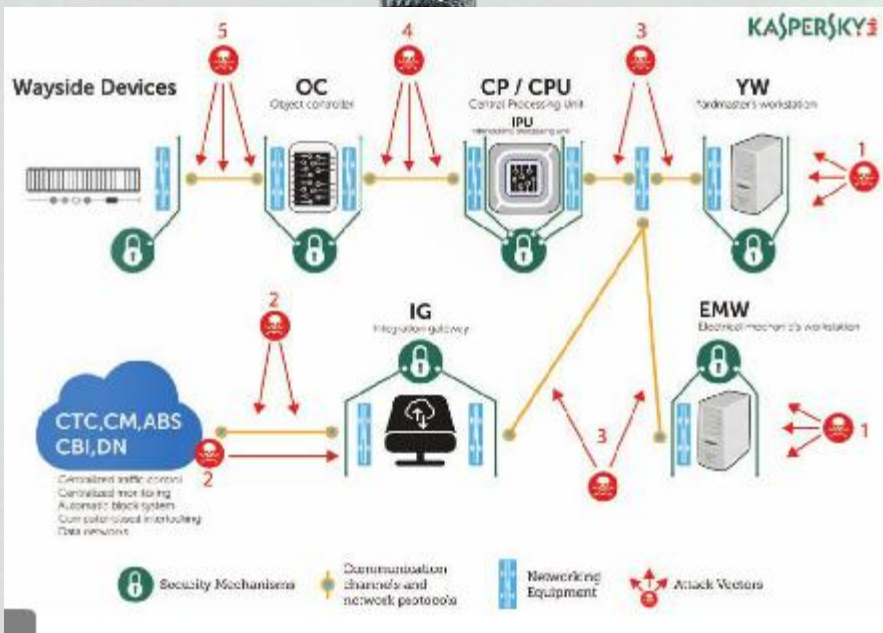
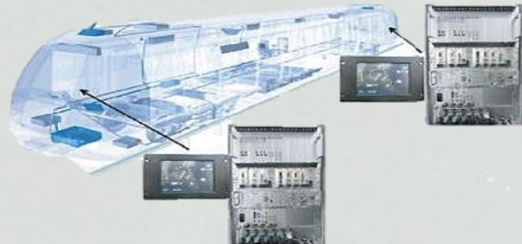
FULL PICTURE



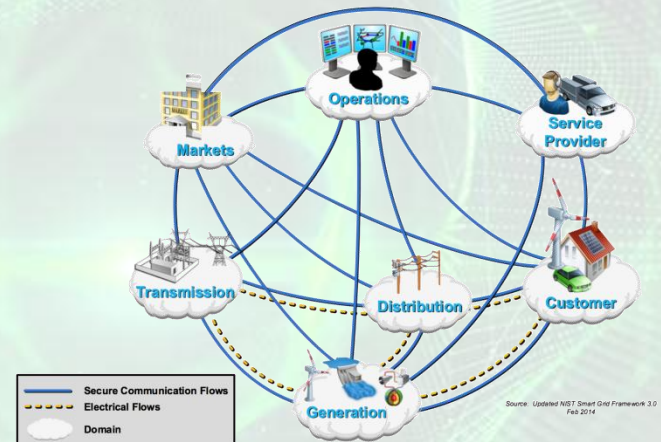
中国互联网安全大会



360互联网安全中心



Conceptual Model



LET DO IT TOGETHER!



中国互联网安全大会



360互联网安全中心

- GOVERNMENT
REGULATORY AUTHORITIES
LAW ENFORCEMENTS
CERTS
- RESEARCHERS
- ICS VENDORS
- SECURITY VENDORS
- OPERATORS OF CRITICAL INFRASTRUCTURE

#SCADASOS



中国互联网络安全大会



360互联网安全中心

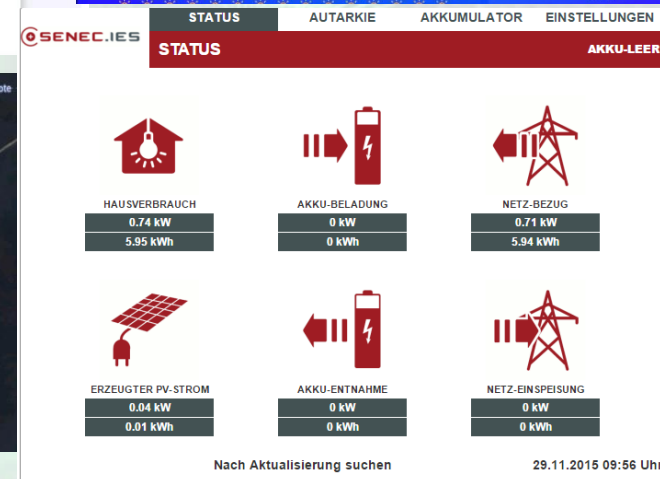
Q: WTF SACADSOS?

A: SCADASOS - (un)Secure Open SmartGrids is open initiative to rise awareness on insecurities of SmartGrid, Photovoltaic Power Stations and Wind Farms.

Q: How to participate

A: Find Internet-connected PV and Wind power stations and notify vendors/CERTs/community.

RT @mmrupp: Another wind farm in Europe with a trivial mistake. It will be added to #SCADASOS tag after fixing.



#SCADASOS RESULTS



中国互联网安全大会



360互联网安全中心

- 60 000+ SmartGrid devices disconnected from the Internet
- Several advisors/patches

Thanks @mmrupp!!!

Advisory (ICSA-15-155-01) [More Advisories](#)
XZERES 442SR Wind Turbine CSRF Vulnerability
Original release date: June 04, 2015

[Print](#) [Tweet](#) [Send](#) [Share](#)

Legal Notice

All information products included in <http://ics-cert.us-cert.gov> are provided "as is" for informational purposes only. The Department of Homeland Security (DHS) does not provide any warranties of any kind regarding any information contained within. DHS does not endorse any commercial product or service, referenced in this product or otherwise. Further dissemination of this product is governed by the Traffic Light Protocol (TLP) marking in the header. For more information about TLP, see <http://www.us-cert.gov/tlp/>.

OVERVIEW

Advisory (ICSA-15-181-02A) [More Advisories](#)
SMA Solar Technology AG Sunny WebBox Hard-Coded Account Vulnerability (Update A)

Original release date: September 03, 2015 | Last revised: September 17, 2015

[Print](#) [Tweet](#) [Send](#) [Share](#)

Legal Notice

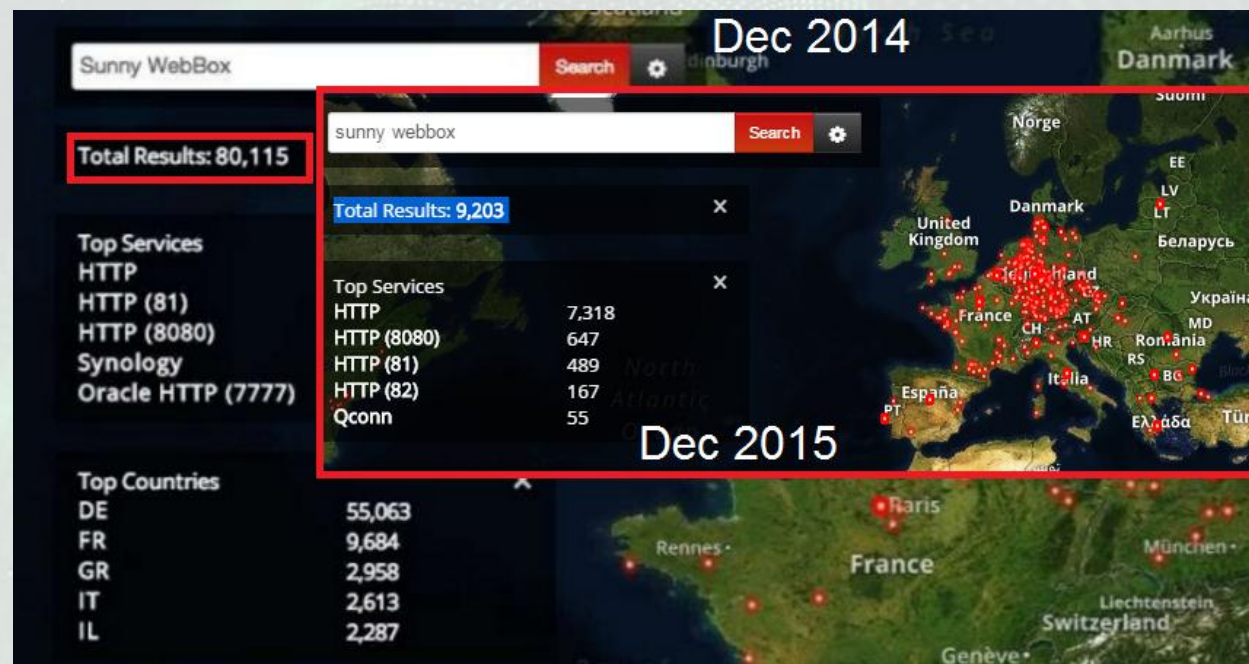
All information products included in <http://ics-cert.us-cert.gov> are provided "as is" for informational purposes only. The Department of Homeland Security (DHS) does not provide any warranties of any kind regarding any information contained within. DHS does not endorse any commercial product or service, referenced in this product or otherwise. Further dissemination of this product is governed by the Traffic Light Protocol (TLP) marking in the header. For more information about TLP, see <http://www.us-cert.gov/tlp/>.

OVERVIEW

This updated advisory is a follow-up to the advisory titled ICSA-15-181-02 SMA Solar Technology AG Sunny WebBox Hard-Coded Account Vulnerability that was published September 3, 2015, on the NCCIC/ICS-CERT web site.

Aleksandr Timorin of PT Security has identified a hard-coded account vulnerability in SMA Solar Technology AG's Sunny WebBox product. SMA is planning to discontinue the sale of this product, and there is no plan to fix old versions. They have reached out to WebBox users with compensating security recommendations.

This vulnerability could be exploited remotely.



THANK YOU FOR COLLABORATION!



中国互联网安全大会



360互联网安全中心



enisa



ICS-CERT

INDUSTRIAL CONTROL SYSTEMS CYBER EMERGENCY RESPONSE TEAM

GovCERT.HK



Schweizerische Eidgenossenschaft
Confédération suisse
Confederazione Svizzera
Confederaziun svizra

Swiss Governmental Computer Emergency Response Team

plcscan.org/blog/



MENU

ICS Security Workspace

专注于工控安全攻防技术研究

Russian GOV CERT

THANKS



中国互联网安全大会



360互联网安全中心

THANKS



中国互联网安全大会



360互联网安全中心

THANKS



中国互联网安全大会



360互联网安全中心

THANKS



中国互联网络安全大会



360互联网安全中心